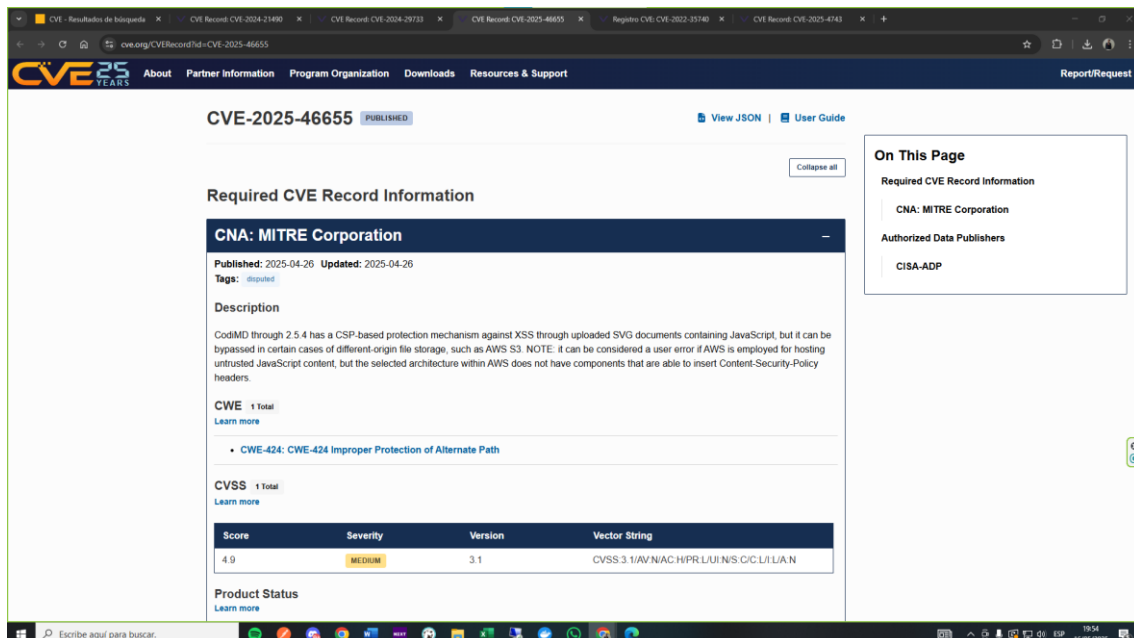


AWS: <https://www.cve.org/CVERecord?id=CVE-2025-46655>

La vulnerabilidad CVE-2025-46655 afecta a CodiMD hasta la versión 2.5.4, una plataforma de código abierto utilizada para crear, editar y compartir documentos colaborativos en tiempo real utilizando el lenguaje Markdown, muy popular en entornos académicos, técnicos y de desarrollo. Esta falla involucra una evasión de políticas de seguridad de contenido (CSP) que permite ataques XSS mediante la carga de archivos SVG maliciosos desde servicios externos como AWS S3, que no aplican correctamente los encabezados CSP. Clasificada con una severidad moderada (CVSS 4.9), puede explotarse sin interacción del usuario y con bajos privilegios. Se recomienda actualizar a una versión posterior a la 2.5.4 y revisar la configuración de seguridad, especialmente si se usa almacenamiento externo.



The screenshot shows the CVE-2025-46655 record page. The page is titled "CVE-2025-46655" and is marked as "PUBLISHED". It includes a "Required CVE Record Information" section with the following details:

- CNA:** MITRE Corporation
- Published:** 2025-04-26 **Updated:** 2025-04-26
- Tags:** disputed
- Description:** CodiMD through 2.5.4 has a CSP-based protection mechanism against XSS through uploaded SVG documents containing JavaScript, but it can be bypassed in certain cases of different-origin file storage, such as AWS S3. NOTE: it can be considered a user error if AWS is employed for hosting untrusted JavaScript content, but the selected architecture within AWS does not have components that are able to insert Content-Security-Policy headers.
- CWE:** 1 Total (Learn more)
 - CWE-424: CWE-424 Improper Protection of Alternate Path
- CVSS:** 1 Total (Learn more)
- Product Status:** (Learn more)

The CVSS section includes a table with the following data:

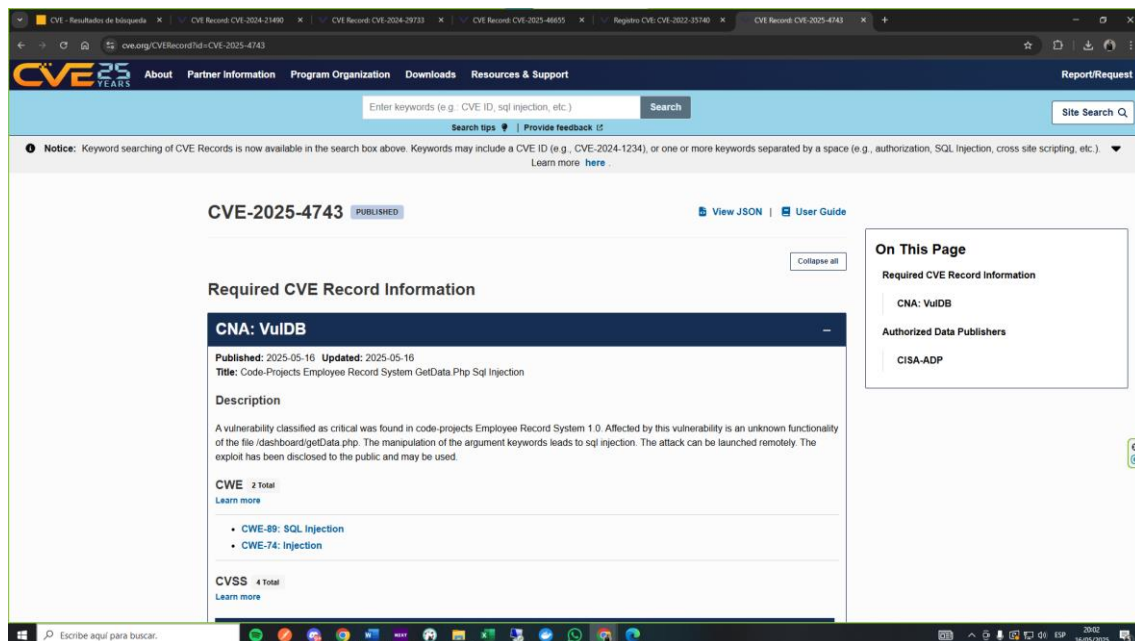
Score	Severity	Version	Vector String
4.9	MEDIUM	3.1	CVSS 3.1/AV:N/AC:H/PR:L/UI:N/S:C/L/L/L/N

The right sidebar contains a section titled "On This Page" with links to "Required CVE Record Information", "CNA: MITRE Corporation", "Authorized Data Publishers", and "CISA-ADP".

FTP: <https://www.cve.org/CVERecord?id=CVE-2024-29733>

La vulnerabilidad CVE-2024-29733 afecta al Apache Airflow FTP Provider en versiones anteriores a la 3.7.0. Apache Airflow es una plataforma de código abierto utilizada para programar, automatizar y monitorear flujos de trabajo de datos. Esta falla se debe a una validación inadecuada de certificados en conexiones FTP_TLS, lo que podría permitir que un atacante intercepte o manipule datos durante la transferencia de archivos. La solución consiste en actualizar a la versión 3.7.0 del proveedor FTP de Airflow, donde se implementa una validación adecuada de certificados mediante la configuración correcta del contexto SSL. Aunque la vulnerabilidad requiere privilegios altos para ser explotada y tiene una

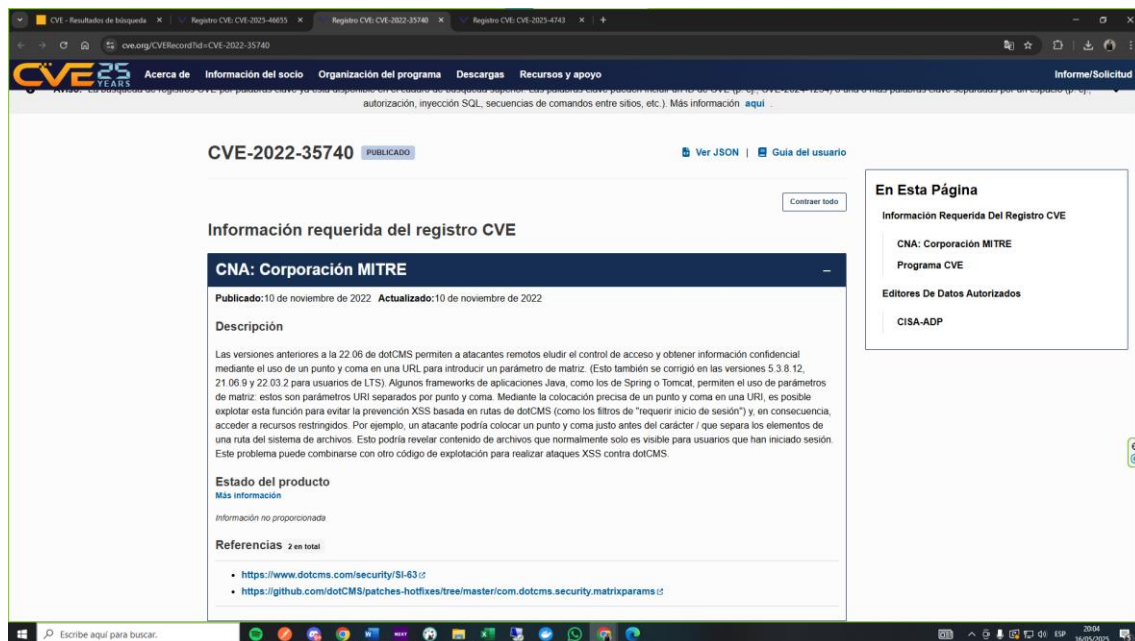
severidad baja (CVSS 2.7), se recomienda encarecidamente aplicar la actualización para garantizar la seguridad de las conexiones FTP en entornos de producción.



Java: <https://www.cve.org/CVERecord?id=CVE-2022-35740>

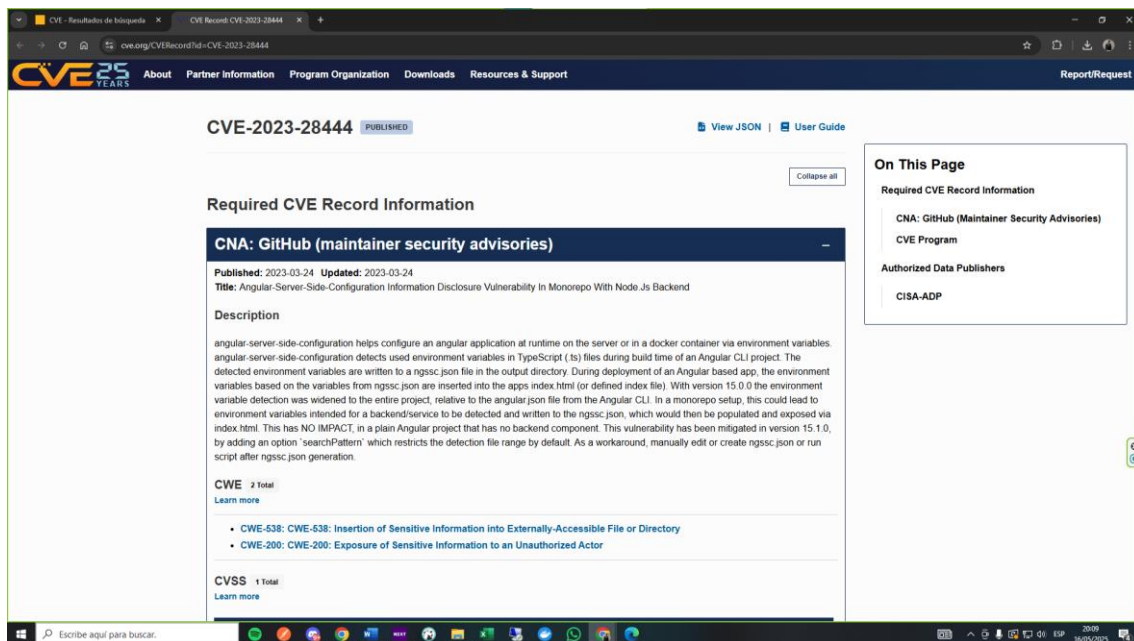
La vulnerabilidad CVE-2022-35740 afecta a dotCMS, un sistema de gestión de contenido (CMS) de código abierto utilizado para crear y administrar sitios web y aplicaciones digitales. Esta falla permite a atacantes remotos eludir los controles de acceso y acceder a información sensible mediante la manipulación de URLs con parámetros de matriz utilizando puntos y coma (;). Al insertar un punto y coma en la URL, es posible evitar los filtros de seguridad basados en rutas, como los que requieren autenticación, y acceder a recursos restringidos. Esta vulnerabilidad puede combinarse con otros métodos para ejecutar ataques de Cross-Site Scripting (XSS) .

Las versiones afectadas son las anteriores a 22.06, y también se ha corregido en las versiones 5.3.8.12, 21.06.9 y 22.03.2 para usuarios de soporte a largo plazo (LTS) . Se recomienda actualizar a estas versiones para mitigar el riesgo.



Angular: <https://www.cve.org/CVERecord?id=CVE-2023-28444>

La vulnerabilidad CVE-2023-28444 afecta al paquete angular-server-side-configuration en las versiones 15.0.0 hasta antes de la 15.1.0. Este paquete se utiliza para configurar aplicaciones Angular en tiempo de ejecución mediante variables de entorno. En entornos de monorepositorios que incluyen componentes backend (como Node.js), la herramienta puede detectar y exponer inadvertidamente variables de entorno sensibles destinadas al backend, insertándolas en el archivo index.html de la aplicación frontend, lo que representa una grave exposición de información. Esta vulnerabilidad ha sido clasificada como crítica con una puntuación CVSS de 9.9. Se recomienda actualizar a la versión 15.1.0 o superior, donde se introdujo la opción searchPattern para restringir el rango de detección de variables. Como solución temporal, se puede editar manualmente el archivo ngssc.json o ejecutar un script posterior a su generación para eliminar variables no deseadas.



SQL: <https://www.cve.org/CVERecord?id=CVE-2025-4743>

La vulnerabilidad CVE-2025-4743 afecta a la versión 1.0 del sistema Employee Record System desarrollado por code-projects, una aplicación usada para gestionar registros de empleados. El fallo reside en el archivo /dashboard/getData.php, donde el parámetro keywords no es validado correctamente, permitiendo una inyección SQL que podría ser explotada remotamente para acceder o modificar datos confidenciales sin necesidad de privilegios elevados ni interacción del usuario. Clasificada como crítica, ya existen pruebas de concepto públicas, por lo que se recomienda actualizar inmediatamente la aplicación, implementar validaciones robustas y utilizar consultas preparadas para mitigar el riesgo.

